O ECOSSISTEMA DE FERRAMENTAS DO KALI

Quem instala o Kali abre o menu, encontra centenas de ferramentas em treze categorias e escolhe a de nome mais chamativo para apontar a algum alvo. É a forma errada de usar a distribuição — e a mais provável de cometer um crime sem entender o que se fez. ***As ferramentas não são o assunto: o fluxo é.***

090
GUIAS LINUX

O CICLO DE UM TESTE — E ONDE CADA CATEGORIA ENTRA

1 RECONHECIMENTO
Mapear **sem tocar**: fontes públicas, DNS, certificados, metadados.
`whois · dig · theHarvester · recon-ng`

→

2 VARREDURA E ENUMERAÇÃO
O que existe e responde. **Aqui começa a interação — e a necessidade de autorização.**
`nmap · masscan · gobuster · enum4linux`

→

3 ANÁLISE DE VULNERABILIDADE
Separa "esta porta está aberta" de "esta versão tem falha conhecida".
`nikto · nuclei · searchsploit · wpscan`

6 RELATÓRIO
O único entregável. Achado, severidade, reprodução, correção.
`faraday · dradis · CherryTree`

←

5 PÓS-EXPLORAÇÃO
Até onde o acesso leva: escalar, pivotar. **Reinicia o ciclo por dentro.**
`linpeas · BloodHound`

←

4 EXPLORAÇÃO
A prova de conceito, controlada — a menor fração do tempo real.
`metasploit · sqlmap · hydra`

O ciclo é iterativo, não linear: a pós-exploração revela hosts e serviços internos invisíveis de fora, e cada descoberta reinicia a varredura — agora de um ponto de vista interno. **As três primeiras fases consomem a maior parte do tempo**, e a fase 6 é a de menos ferramenta e mais valor: **o cliente paga pelo relatório, não pelo acesso**. Um acesso obtido e não documentado de forma reproduzível não vale nada.

ANTES DE QUALQUER FERRAMENTA: O ESCOPO ASSINADO

QUAIS ALVOS	QUAIS TÉCNICAS	QUAL JANELA	QUEM ASSINA	CONTATO DE EMERGÊNCIA
IPs, domínios e faixas **exatos**. O IP vizinho do mesmo bloco não entra por proximidade.	Negação de serviço, engenharia social e exploração ativa costumam ficar de fora.	Datas e horários. Testar fora deles é agir **sem autorização**.	Quem tem poder legal sobre os sistemas — o administrador pode não ser essa pessoa.	Para quando algo sai do previsto. Às vezes sai.

A ferramenta é idêntica; o que muda é o papel. `nmap`, `hydra`, `sqlmap` e `metasploit` fazem exatamente a mesma coisa nas mãos de um *pentester* contratado e nas de um criminoso — a lei não distingue os dois pela ferramenta, e sim pela existência de **autorização escrita, específica e prévia** para aquele alvo, naquela janela, com aquelas técnicas. No Brasil, a **Lei 12.737/2012** tipifica a invasão de dispositivo informático alheio com pena de detenção: *alheio* e *indevida* são as palavras que importam, e valem independentemente de ter havido dano, da intenção declarada ou de a ferramenta ser pública. Varrer as portas de um servidor de terceiro já é o começo do que a lei descreve; a **LGPD** acrescenta responsabilidade sobre qualquer dado pessoal que o teste venha a tocar.

INSTALAR MENOS, NÃO MAIS — E TER ONDE PRATICAR

kali@kali: ~

```
# metapacotes: conjuntos coerentes, não ferramenta a ferramenta
$ apt search '^kali-tools-' | head -30
$ sudo apt install kali-tools-web
$ kali-tweaks  # o painel: metapacotes, hardening, shell
# wordlists — a rockyou vem compactada na 1ª vez
$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz
# o banco que dá memória ao Metasploit entre sessões
$ sudo msfdb init  # e desative quando não usar
# o fluxo, contra alvo de treino em rede isolada:
$ whois exemplo.com; dig +short exemplo.com  # fase 1
$ nmap -sV -sC -p- 10.10.10.5                # fase 2
$ gobuster dir -u http://10.10.10.5 -w common.txt
$ searchsploit apache 2.4; nikto -h http://10.10.10.5
$ msfconsole                                 # fase 4
```

METAPACOTE	O QUE TRAZ
`kali-linux-headless`	o núcleo, sem interface gráfica
`kali-linux-default`	o conjunto padrão da imagem — **comece aqui**
`kali-tools-web`	ferramental de aplicação web
`kali-tools-passwords`	quebra de senha e força bruta
`kali-tools-wireless`	ataque e auditoria de Wi-Fi
`kali-linux-everything`	literalmente tudo — **e não é o que você quer**

Instale menos, não mais: uma máquina com `everything` é superfície de ataque imensa, atualização lenta e centenas de programas que você nunca abrirá. E **a regra de ouro do laboratório é o isolamento de rede** — uma VM deliberadamente vulnerável (Metasploitable, DVWA, *Juice Shop*) é, por definição, uma máquina que qualquer um compromete em minutos: ela vai em rede *host-only* ou interna do hipervisor, **jamais em ponte com a rede real**.

RESUMO RÁPIDO

- ✓ **A ferramenta é a mesma nas duas mãos; o que muda é a autorização** — escrita, específica e prévia, com alvos, técnicas, janela e quem assina.
- ✓ **O assunto não são as ferramentas, é o fluxo:** reconhecimento → varredura → análise → exploração → pós-exploração → relatório.
- ✓ **O ciclo é iterativo:** a pós-exploração revela alvos internos e reinicia a varredura de dentro.
- ✓ **A exploração é a menor fração do tempo; o relatório é o entregável.** Acesso não documentado não vale nada.
- ✓ **Metapacotes organizam as centenas de ferramentas** — e a recomendação contraria a tentação: instale menos.
- ✓ **Prática legal só contra a própria máquina ou alvo de treino**, sempre em rede isolada.

NO KALI

`kali-tweaks` **é o painel de controle da distribuição e a primeira coisa a abrir numa instalação nova:** gerencia metapacotes, rede, comportamento do shell, persistência da imagem *live* e o *hardening* — tudo num menu navegável e reversível. Muita gente instala ferramenta na mão por não saber que ele existe. **O modo *undercover* tem motivo prático e legítimo:** `kali-undercover` transforma a área de trabalho num clone visual do Windows 10 — num teste físico autorizado, ou trabalhando num café, a tela inconfundível do Kali chama atenção que o profissional não quer. É disfarce da interface, **não das ferramentas nem da responsabilidade legal.** `msfdb init` **na primeira execução vale a pena:** cria a base PostgreSQL onde o Metasploit guarda hosts, serviços e achados, que é justamente o que alimenta a fase de relatório — mas é também um serviço a mais escutando na sua máquina, então ative quando for usar. **As *wordlists* em** `/usr/share/wordlists` **são o argumento vivo a favor de chave em vez de senha:** tudo que está na `rockyou.txt` é quebrável em segundos. **A ferramenta do Kali é dual por natureza, e essa é a lição que fecha o volume:** o `nmap` que enumera o alvo é o mesmo que audita a própria superfície; o `linpeas` que mapeia escalada na pós-exploração é o inventário de SUID e capabilities do guia 087 lido do outro lado; o `nikto` que acha má configuração no alvo acha a mesma coisa no seu servidor. **Aprender o Kali é aprender a olhar o próprio sistema com os olhos de quem vai atacá-lo** — e é para isso, legalmente, que ele serve na esmagadora maioria das mãos. **Outras distribuições ofensivas: Parrot OS Security** (foco em privacidade, mais leve), **BlackArch** (milhares de ferramentas sobre Arch) e **Commando VM** (o análogo para Windows) partilham a mesma natureza dual e a mesma exigência de autorização — a distribuição muda a embalagem, não a lei. Do lado defensivo, o **Security Onion** monta o outro polo: monitoramento, detecção e análise em vez de ataque.